

CYMAG AutoScanner v1.1

Relatório de Diagnóstico de Segurança

Alvo	10.10.100.0/24
Data	09/06/2026 14:55:57
Achados	19
CRÍTICO	10
ALTO	1
MÉDIO	4
BAIXO	4

Achados de Segurança

[CRÍTICO] SQL Injection Detectado CVSS 9.8	
Host	10.10.100.100:80 — HTTP
Descrição	Endpoint retorna erros SQL ao receber entrada malformada. Pode permitir extração completa do banco de dados.
Evidência	GET /api/collaborators?name=' → erro SQL na resposta

[CRÍTICO] Broken Authentication — Token Base64 Forjável CVSS 9.1	
Host	10.10.100.100:80 — HTTP
Descrição	O token de sessão é Base64 de usuario:role:contexto sem assinatura criptográfica. Qualquer usuário pode forjar um token de administrador.
Evidência	Token forjado aceito em /admin (HTTP 200)

[CRÍTICO] Node-RED Sem Autenticação CVSS 9.8	
Host	10.10.100.100:1880 — Node-RED
Descrição	Interface administrativa do Node-RED v4.1.10 acessível sem credenciais. Controle total sobre fluxos OT.
Evidência	GET /settings → 200 v4.1.10 funcExtModules:True

[CRÍTICO] RCE Potencial — functionExternalModules Ativo CVSS 9.1	
Host	10.10.100.100:1880 — Node-RED
Descrição	A flag functionExternalModules:true permite carregar child_process e executar comandos no SO do servidor.
Evidência	"functionExternalModules": true

[CRÍTICO] Código-Fonte de Automação Exposto CVSS 8.6	
Host	10.10.100.100:1880 — Node-RED
Descrição	37 nós de automação acessíveis sem autenticação.
Evidência	GET /flows → 200 37 nós

[CRÍTICO] Sistema SCADA/OT de Bombas Exposto CVSS 9.5	
Host	10.10.100.100:1880 — Node-RED
Descrição	Flows expõem sistema industrial de monitoramento de bombas. Permite injeção de telemetria falsa.
Evidência	Tópicos MQTT industriais detectados nos flows

[CRÍTICO] Broker MQTT Sem Autenticação e Sem TLS CVSS 9.3	
Host	10.10.100.100:1883 — MQTT
Descrição	Broker MQTT aceita conexões anônimas e transmite dados em texto claro. Qualquer dispositivo pode publicar ou assinar qualquer tópico industrial.
Evidência	Conexão anônima aceita na porta 1883/tcp (sem TLS)

[CRÍTICO] MySQL 5.5.62 — EOL sem patches desde 2018 CVSS 9.8	
Host	10.10.100.100:3307 — MySQL
Descrição	MySQL 5.5.62 atingiu End-of-Life em 2018. Múltiplas CVEs críticas sem correção disponível.
Evidência	Versão: MySQL 5.5.62

[CRÍTICO] SMB Signing Desabilitado — NTLM Relay Viável CVSS 9.0	
Host	10.10.100.2:139 — SMB
Descrição	Sem assinatura SMB, ataques NTLM Relay são viáveis. Em ambientes com Active Directory, isso pode levar ao comprometimento total do domínio.
Evidência	SMB Signing: disabled/not required

[CRÍTICO] SMB Signing Desabilitado — NTLM Relay Viável CVSS 9.0	
Host	10.10.100.2:445 — SMB
Descrição	Sem assinatura SMB, ataques NTLM Relay são viáveis. Em ambientes com Active Directory, isso pode levar ao comprometimento total do domínio.
Evidência	SMB Signing: disabled/not required [*] Windows 10 / Server 2016 Build 17134 x64 (name:WIN10101002) (domain:corp.local) (signing:False) (SMBv1:False) Host: WIN10101002

[ALTO] Endpoint Sensível Exposto: /api/collaborators CVSS 7.5	
Host	10.10.100.100:80 — HTTP
Descrição	Endpoint de Colaboradores acessível sem autenticação adequada.

Evidência	GET /api/collaborators → HTTP 200	
-----------	-----------------------------------	--

[MÉDIO]	Headers de Segurança Ausentes	CVSS 5.3
Host	10.10.100.100:80 — HTTP	
Descrição	A aplicação não implementa headers de segurança HTTP recomendados, deixando usuários expostos a ataques como clickjacking e XSS.	
Evidência	Ausentes: X-Content-Type-Options, X-Frame-Options, Content-Security-Policy, Strict-Transport-Security	

[MÉDIO]	Endpoint Sensível Exposto: /admin	CVSS 5.0
Host	10.10.100.100:80 — HTTP	
Descrição	Painel Administrativo acessível sem autenticação adequada.	
Evidência	GET /admin → HTTP 401	

[MÉDIO]	RPC Endpoint Mapper Exposto	CVSS 5.3
Host	10.10.100.2:135 — RPC	
Descrição	A porta 135 (RPC Endpoint Mapper) está acessível. Pode ser usada para enumeração de serviços RPC registrados e movimentação lateral em ambientes Windows/AD.	
Evidência	Porta 135/tcp aberta em 10.10.100.2	

[MÉDIO]	RPC Endpoint Mapper Exposto	CVSS 5.3
Host	10.10.100.3:135 — RPC	
Descrição	A porta 135 (RPC Endpoint Mapper) está acessível. Pode ser usada para enumeração de serviços RPC registrados e movimentação lateral em ambientes Windows/AD.	
Evidência	Porta 135/tcp aberta em 10.10.100.3	

[BAIXO]	Divulgação de Versão do Servidor Web	CVSS 3.1
Host	10.10.100.100:80 — HTTP	
Descrição	O header Server revela versão exata, facilitando ataques direcionados.	
Evidência	Server: nginx/1.24.0	

[BAIXO]	MySQL em Porta Não Padrão (3307)	CVSS 2.0
Host	10.10.100.100:3307 — MySQL	
Descrição	Porta não padrão não é medida de segurança efetiva.	
Evidência	MySQL em 3307/tcp	

[BAIXO]	Serviços RPC Enumerados	CVSS 3.1
Host	10.10.100.2:135 — RPC	
Descrição	Serviços RPC enumerados sem autenticação. Pode revelar serviços internos e versões.	
Evidência	Serviços: [MS-RSP]: Remote Shutdown Protocol , N/A , N/A , N/A , N/A	

[BAIXO] Serviços RPC Enumerados		CVSS 3.1
Host	10.10.100.3:135 — RPC	
Descrição	Serviços RPC enumerados sem autenticação. Pode revelar serviços internos e versões.	
Evidência	Serviços: [MS-RSP]: Remote Shutdown Protocol , N/A , N/A , N/A , N/A	

AVISO LEGAL: Relatório gerado automaticamente. Resultados podem conter imprecisões. Revisão por especialista em segurança é obrigatória antes de qualquer decisão.